

Low-Level Protocol Exploitation and Physical-Layer Defenses for NFC Smart Lock Systems

NUSSoC 2026 Summer Workshop DADA Project Report

Xinjie Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
kawaiishinsuguru@gmail.com

Yulin Li
College of Computer Science and
Technology, Zhejiang University
Hangzhou, China
LeenSed@163.com

Chengfeier Pei
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
faye-official@sjtu.edu.cn

Canyu Liu
Chu Kou Chen College, Zhejiang
University
Hangzhou, China
liucanyu0411@gmail.com

Peize Yang
School of Integrated Circuits,
Shanghai Jiao Tong University
Shanghai, China
legacy1083@sjtu.edu.cn

Abstract

Near Field Communication (NFC) technology has become ubiquitous in information exchange and access control, such as contactless payments and smart locks. As sensitive applications multiply, these systems increasingly attract sophisticated adversarial exploits, demanding a broader consideration of potential threat vectors. In this project, we focus on two complementary aspects of NFC smart lock security. On the attack side, we employ a Proxmark3 platform to demonstrate full credential recovery from MIFARE Classic 1K cards by exploiting weaknesses in the proprietary Crypto-1 cipher, and subsequently produce functional clones using rewritable Magic Cards. On the defense side, we use a HackRF One Software Defined Radio to capture the raw 13.56 MHz physical-layer signals during card-reader interactions and extract radio-frequency fingerprints—such as carrier frequency offset, modulation transient shape, and RSSI profile—that are unique to each physical card and inherently non-transferable through cloning. This dual approach establishes both an end-to-end attack demonstration and a hardware-grounded countermeasure that operates below the protocol layer.

Keywords

NFC Security, MIFARE Classic, Crypto-1, Proxmark3, SDR Fingerprinting

1 Introduction

1.1 NFC Technology

Near Field Communication (NFC) is a short-range wireless technology operating at 13.56 MHz within the High Frequency (HF) band of the RFID spectrum. As a subset of Radio Frequency Identification (RFID) standardized under ISO/IEC 14443 [2], NFC enables bidirectional data exchange between an active initiator device and a passive or active target within a typical range of 4–10 cm.

Unlike far-field RFID systems that rely on electromagnetic wave propagation, NFC communication is strictly based on inductive coupling between two coil antennas. The initiator (e.g., a smart lock reader) generates an alternating magnetic field, which induces

a current in the target's coil (e.g., a keycard or smartphone), thereby powering the target. The target responds by modulating its coil impedance, a technique known as load modulation, which the initiator detects as amplitude variations on the carrier. Two encoding schemes are defined for proximity cards under ISO/IEC 14443 Type A: Modified Miller encoding with 100% amplitude shift keying (ASK) for reader-to-card communication, and Manchester encoding with subcarrier load modulation for card-to-reader responses, typically at a data rate of 106 kbps [3].

The widespread adoption of NFC in access control, contactless payment, and identity verification has made these systems a high-value target for adversaries [4]. Although the short operational range inherently limits remote eavesdropping, the physical layer remains susceptible to close-range sniffing and replay attacks. This vulnerability forms the primary motivation for hardware-defined defense paradigms explored in this work.

1.2 Security Threats in NFC Systems

Despite the short communication range, NFC has accumulated an increasingly diverse threat landscape over the past two decades. Early analyses by Haselsteiner and Breitfuß [5] identified canonical attack categories—eavesdropping, data manipulation, and relay—that remain relevant but have been significantly amplified by cheaper hardware and open-source toolchains. Figure 1 illustrates the growth in documented NFC and high-frequency RFID exploits between 2006 and 2024, compiled from peer-reviewed publications and CVE entries. The number of publicly reported attack techniques has roughly tripled over this period, with a noticeable acceleration after 2018 driven by the availability of low-cost SDR platforms such as the HackRF One and the Proxmark3 ecosystem [1].

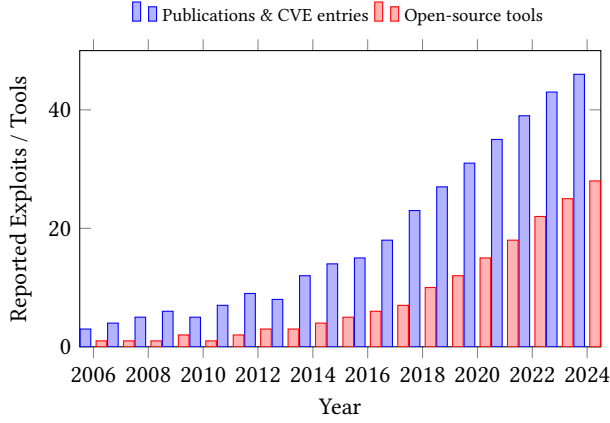


Figure 1: Growth of documented NFC/RFID exploits and open-source attack tools (2006–2024). Data from peer-reviewed literature and the CVE database.

Beyond raw quantity, the diversity of attack vectors has expanded considerably, as summarized in Figure 2. Early threats were largely limited to passive eavesdropping and relay; modern adversaries now employ card emulation, side-channel analysis, algebraic key-recovery, and multi-layer protocol exploitation [4]. The emergence of the “Chinese Magic Card” (rewritable Block 0 MIFARE chips) has further commoditised cloning attacks, enabling an attacker to duplicate both the UID and the sector payload without specialist fabrication equipment.

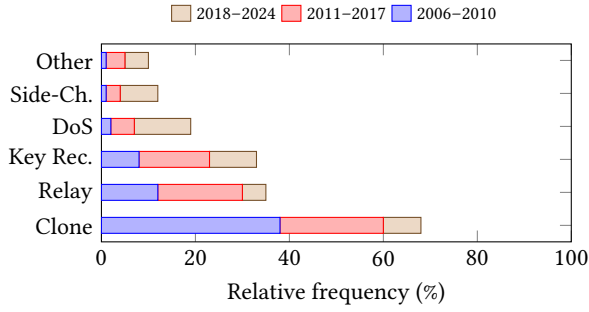


Figure 2: Evolution of NFC attack-vector distribution across three time periods. Cloning and relay remain dominant, but key-recovery and denial-of-service attacks have grown notably since 2018.

Beyond raw quantity, the diversity of attack vectors has expanded considerably, as summarized in Figure 2. Early threats were largely limited to passive eavesdropping and relay; modern adversaries now employ card emulation, side-channel analysis, algebraic key-recovery, and multi-layer protocol exploitation [4]. The emergence of the “Chinese Magic Card” (rewritable Block 0 MIFARE chips) has further commoditised cloning attacks, enabling an attacker to duplicate both the UID and the sector payload without specialist fabrication equipment.

The combination of a growing attack surface and commodity-grade offensive hardware has eroded the implicit “proximity-equals-security” assumption on which most NFC access-control deployments were originally designed. This motivates the need for defense mechanisms that operate below the protocol layer, at the physical radio interface, where adversarial presence can be detected from signal-level anomalies rather than from credential content alone.

1.3 Contributions and Paper Organization

In this work, we investigate NFC smart lock security from both adversarial and defensive perspectives, using openly available hardware and software toolchains. Our principal contributions are as follows:

- (1) **End-to-end attack demonstration.** We replicate a complete credential-recovery and card-cloning attack against MIFARE Classic 1K access cards, leveraging a Proxmark3 platform to exploit the well-documented weaknesses of the Crypto-1 stream cipher. The attack chain covers nonce collection, key recovery, sector dump, and production of a functional clone using rewritable Magic Cards.
- (2) **Physical-layer anti-cloning defense.** We propose a defense strategy that operates at the 13.56 MHz RF physical layer, independent of the upper-layer protocol. By capturing reader-card interactions with a HackRF One SDR and analyzing per-card signal fingerprints, we create a verification pipeline that can distinguish a genuine card from an identical clone.
- (3) **Integrated prototype system.** We build and release a cross-platform smart lock implementation that combines standard PCSC card I/O with the SDR-based fingerprint verification, serving as a reproducible testbed for both attack and defense evaluation.

The remainder of this paper is organized as follows. Section 2 provides background on MIFARE Classic and the Crypto-1 cipher. Section 3 analyzes the theoretical weaknesses of Crypto-1 and the key-recovery attack, while Section 4 presents our practical Proxmark3-based implementation and cloning results. Section 5 introduces the physical-layer fingerprinting defense in theory, and Section 6 describes its SDR-based implementation and integration into the door lock prototype. Section 7 discusses limitations and future work, and Section 8 concludes.

2 MIFARE Classic and Crypto-1

2.1 MIFARE Classic Memory Architecture

The MIFARE Classic 1K is one of the most widely deployed contactless smart cards globally, consisting of a chip, antenna, and card body as illustrated in Figure 3.

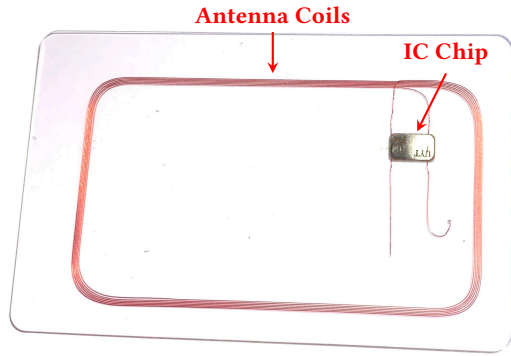


Figure 3: MIFARE Classic 1K

Operating at 13.56 MHz, it complies with parts 1–3 of the ISO/IEC 14443 Type A standard but diverges at the application layer by employing a proprietary protocol and cryptographic algorithm for access control [3]. The 1K variant features 1024 bytes of EEPROM, which is partitioned into 16 discrete sectors (numbered 0 to 15), as illustrated in Figure 4.

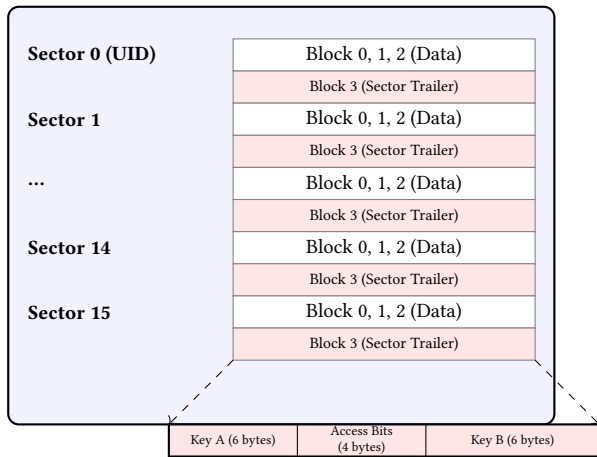


Figure 4: MIFARE Classic 1K memory organization and Sector Trailer structure.

Each sector consists of four 16-byte blocks. The first three blocks (Blocks 0–2) are allocated for user data storage. A notable exception is Block 0 of Sector 0, which is programmed during silicon manufacturing and contains the 4-byte or 7-byte Unique Identifier (UID) alongside vendor data. By design, this block is permanently write-protected on authentic tags. The final block of every sector, known as the Sector Trailer (Block 3), dictates the access control policies for that specific sector. It holds two 48-bit authentication keys (Key A and Key B) separated by four bytes of access conditions. These conditions define the read and write permissions for the data blocks and the sector trailer itself, dependent on which key is successfully authenticated.

2.2 The Crypto-1 Stream Cipher

To protect data transmission and enforce sector-level access control, NXP Semiconductors implemented Crypto-1, a proprietary stream cipher. The algorithm’s design was kept secret under the premise of security through obscurity until it was successfully reverse-engineered by Garcia et al. in 2008 through microscopic silicon analysis [6].

Crypto-1 utilizes a 48-bit Linear Feedback Shift Register (LFSR) combined with a multi-layered non-linear boolean filter function $f(x)$ (Figure 5). The LFSR state is updated at each clock cycle based on a primitive feedback polynomial over GF(2). The generated keystream is subsequently XORed with the plaintext to produce ciphertext during reader-card over-the-air communication.

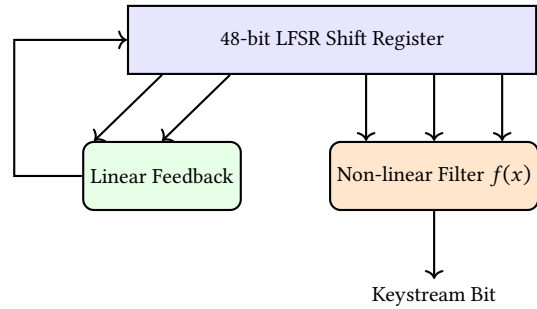


Figure 5: High-level architecture of the Crypto-1 stream cipher.

The sector authentication process relies on a three-pass mutual authentication protocol:

- (1) **Challenge:** The reader requests authentication for a specific sector block, and the card responds with a 32-bit random nonce (n_T).
- (2) **Response & Reader Nonce:** The reader responds with its own 32-bit nonce (n_R) and the encrypted answer to the card’s challenge, computed using the shared 48-bit sector key and the initial LFSR state.
- (3) **Card Verification:** If the reader’s response is correct, the card replies with the encrypted answer to the reader’s challenge, concluding the cryptographic handshake.

Despite its efficiency in resource-constrained environments, Crypto-1 exhibits several critical cryptographic flaws. The 48-bit key space is susceptible to brute-force attacks on modern hardware. More importantly, the reliance on a predictable pseudo-random number generator (PRNG) for generating n_T and the malleability of the parity bits in the ISO 14443-A framing allow attackers to deduce the internal LFSR state, leading to near-instantaneous key recovery attacks which are explored in Section ??.

3 Smart Lock System Implementation

为了展开后续的攻防实践，我们在此基于上述的 MIFARE Classic 1K 卡片的交互原理、Crypto-1 加密算法及相关的 NFC 通信协议，使用 C 语言构建了一款可用于与加密卡交互的智能门锁系统。目前，该系统的核心功能为根据读取的信息验证身

份,并决定是否发出开锁信号。因此,其他人可根据源码预留的接口驱动其他门锁组件进行实际的开关锁操作。

3.1 System Architecture

智能门锁系统的总体架构由三个逻辑层次构成,如图6所示:最顶层为运行于宿主机上的锁守护进程(lock)和卡片管理工具(lock_admin),中间层为操作系统的PC/SC智能卡框架,最底层为通过USB CCID接口连接的ACR122U NFC读写器及被感应的MIFARE Classic 1K门禁卡。

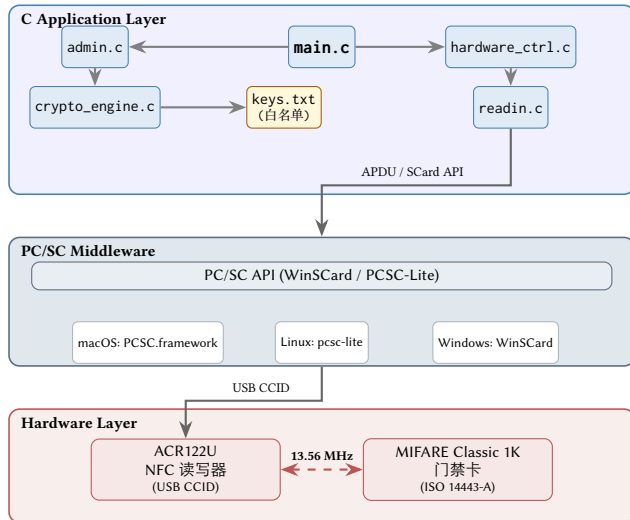


Figure 6: 智能门锁系统三层架构。

系统被构建为两个独立的可执行文件（共享同一代码库），分别承担不同的角色：

- lock——门锁守护进程。以无限循环方式运行，不断等待卡片靠近、执行身份验证、根据验证结果控制LED灯信号和蜂鸣器提示，并记录访问事件。
- lock_admin——卡片发行与管理工具。用于将凭证数据（加密密钥、访问等级、有效期等）写入空白卡片，完成卡片初始化与注册。

系统的核心代码组织在src/目录下，结构如下：

main.c (224行)是锁守护进程的入口点。它首先解析命令行参数（--keyfile指定白名单文件路径，--keya可自定义Key A），安装操作系统信号处理器（SIGINT、SIGTERM、SIGHUP）以保证退出时释放PC/SC资源，然后初始化PC/SC上下文并自动选择名中包含“ACR122”或“ACR12”的读卡器。之后进入无限主循环：等待卡片靠近→连接卡片→调用auth_verify_card()验证凭证→根据返回值控制LED信号→断开连接→等待卡片移走，循环往复。

admin.c (331行)是管理工具lock_admin的实现。通过参数--level设置访问等级，--expiry设置有效期（BCD编码）、--keya设置自定义密钥，--format-trailer控制是否格式化扇区尾块。程序在用户放置卡片并按回车后执行写卡操作：将凭证头写入Block 4、随机生成的8字节凭证密钥写入Block 5、发行日期和有效期写入Block 6，并进行写后回读验证。凭证密钥由标准库rand()生成。

crypto_engine.c (599行)是整个系统最关键的模块，封装了所有MIFARE Classic卡片的密码学操作。主要函数包括：

- apdu_send() / apdu_ok()——APDU指令的发送与应答校验
- mifare_load_key()——向ACR122U密钥槽加载Key A
- mifare_authenticate()——执行三次相互认证
- mifare_read_block() / mifare_write_block()——加密会话下的数据块读写
- auth_verify_card()——凭证全链路验证（详见§3.3）
- load_whitelist() / is_in_whitelist()——白名单加载与匹配

readin.c (113行)提供PC/SC的跨平台抽象层，封装了上下文建立、读卡器枚举、卡片连接/断开、等待卡片到位/移走等操作。所有底层API差异（macOS的PCSC.framework、Linux的libpcsc-lite、Windows的WinSCard）由条件编译统一处理。

hardware_ctrl.c (64行)实现LED灯和蜂鸣器的硬件控制。ACR122U的LED/蜂鸣器通过厂商特定APDU指令（CLA 0xFF，INS 0x40）进行控制：验证通过时发送绿色LED闪烁（状态0x08，500ms间隔），验证失败时发送红色LED闪烁（状态0x04，200ms间隔）三次。

3.2 Hardware Components

本系统的硬件组成遵循典型的商用智能门锁方案架构。核心硬件包括三个部分：NFC读写器、门禁卡片和宿主机。

3.2.1 ACR122U NFC读写器. ACR122U(及兼容型号如ACR122T)是Advanced Card Systems Ltd. (ACS)生产的一款符合CCID标准的非接触式智能卡读写器，作为本系统的门端读卡装置。它通过USB全速接口（12 Mbps）与宿主机通信，遵循USB CCID设备类规范，操作系统无需安装专有驱动即可通过标准PC/SC框架进行访问。

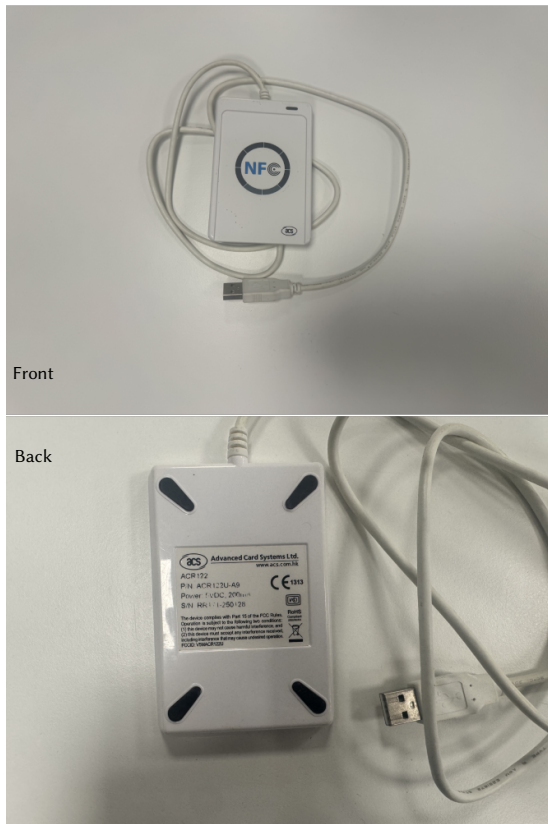


Figure 7: ACR122U

该读写器的核心射频组件工作于 13.56 MHz，兼容 ISO/IEC 14443 Type A 和 Type B 协议。对于 MIFARE Classic 卡片，ACR122U 在固件中集成了 Crypto-1 硬件引擎，能够在设备内部完成三次相互认证的密码学运算。这意味着上位机端的软件仅需通过 APDU 指令向读写器发送 Key A (FF 82 00 00 06 <key>) 和认证命令 (FF 86 00 00 05 01 00 <block> 60 00)，即可获得认证成功/失败的状态码——原始的非交互挑战/应答序列 (n_T 、 n_R 、 a_R 、 a_T) 在上位机侧不可见，加密和解密过程完全在读写器内部完成。这一特性简化了上位机软件开发，但也意味着若要嗅探原始 RF 信号或捕获认证序列，必须借助 Proxmark3 等专用工具在物理层旁路监听。

读写器内置可编程的双色 LED 灯 (红/绿) 和蜂鸣器。本系统通过厂商自定义 APDU FF 00 40 直接控制它们，以实现访问授权/拒绝的视觉反馈。LED 控制指令通过 P2 参数区分状态：0x08 对应绿色 LED 闪烁，0x0C 对应关闭 LED，0x04 对应红色 LED 闪烁。闪烁的占空比由发送指令的时间间隔控制 (验证通过时 500ms，拒绝时 200ms)。

3.2.2 MIFARE Classic 1K 门禁卡片。 系统使用 NXP 半导体生产的 MIFARE Classic 1K (S50) 作为用户门禁卡。该卡片的具体内存布局和加密特性已在第 2 节中详细描述，此处仅从门锁系统的应用角度说明凭证数据的组织方式。

系统使用了卡片的 Sector 1 (Block 4-7，即第二个扇区) 来存储门禁凭证。Sector 0 保留给制造商的 UID 和出厂数据，Sectors 2-15 在本系统不使用。Sector 1 中各块的用途如表 1 所示。

Table 1: Sector 1 凭证数据布局

块号	名称	内容
Block 4	凭证头	魔术字符串 "LOCK" (4 字节) + 卡片序列号 (4 字节) + 访问等级 (2 字节) + 保留 (6 字节)
Block 5	凭证密钥	随机生成的 8 字节凭证密钥 + 保留 (8 字节)
Block 6	元数据	发行日期 BCD (4 字节) + 有效期 BCD (4 字节) + 保留 (8 字节)
Block 7	扇区尾块	Key A (6 字节) + 访问条件 (4 字节) + Key B (6 字节)

凭证头的魔术字符串 "LOCK" 用于识别该卡片是否为本系统发放的门禁卡。卡片序列号字段存储了卡片物理 UID 的前 4 字节，在每次验证时与实际卡片 UID 进行比对，作为反克隆的基础措施。凭证密钥为 lock_admin 发行时随机生成的 8 字节密钥，在宿主机的白名单文件 keys.txt 中注册，构成离线白名单访问控制系统。有效期采用 BCD 编码 (例如 2026 年 12 月 31 日表示为字节序列 0x20 0x26 0x12 0x31)，由系统时钟在每次验证时进行比对检查。

系统默认使用出厂密钥 FF FF FF FF FF FF 作为 Sector 1 的 Key A，可在运行时通过 --keya 参数指定自定义密钥。访问条件 (默认为 FF 07 80 69) 编码为 Key A 不可读 (仅可写)，Key B 可读写，由 Key A 认证后可读取所有数据块但不能写入。该策略确保了门锁守护进程仅需知道 Key A 即可完成验证，管理工具需要 Key A 进行写卡操作，而卡片内容不会被非授权方轻易读出。

3.3 Authentication and Verification Pipeline

一次完整的卡片认证与验证流程，从卡片靠近到门锁决策，共经历以下七个阶段。该流程由 crypto_engine.c 中的 auth_verify_card() 函数统一协调。

阶段 1: 卡片到位检测。 守护进程通过 pcsc_wait_for_card() 阻塞等待读卡器报告卡片就位。该函数内部使用 SCardGetStatusChange() 轮询读卡器状态，当状态字中的 SCARD_STATE_PRESENT 位被置位时返回。

阶段 2: 建立连接与读取 UID。 调用 SCardConnect() 以共享模式 (SCARD_SHARE_SHARED) 连接卡片，同时协商传输协议 (T=0 或 T=1)。随后通过 APDU FF CA 00 00 00 (Get Data) 读取卡片的物理 UID。UID 长度为 4 或 7 字节 (MIFARE Classic 1K 通常为 4 字节)，提取前 4 字节用于后续与存储序列号的比对。

阶段 3: 加载密钥与三次相互认证。 通过 APDU FF 82 00 00 06 <Key A> 将 Sector 1 的 Key A 加载到 ACR122U 的易失性密钥槽中。随后发送认证指令 FF 86 00 00 05 01 00 04 60 00，指示读写器对 Block 4 (Sector 1 的第一个数据块) 执行 Crypto-1 三次相互认证。此认证由 ACR122U 内部硬件引擎完成，主控端仅收到成功 (SW=90 00) 或失败 (SW=63 Cx，其中 x 为剩余重试次数) 的状态码。

阶段 4: 凭证头验证。 认证通过后，加密会话已建立。通过 APDU FF B0 00 04 10 读取 Block 4 的 16 字节完整内容。首先检查前 4 字节是否等于魔术字符串 "LOCK"，以确认该卡片为本系统发放的门禁卡。然后提取 Block 4 中存储的 4 字节序列号 (偏移 4-7)，与阶段 2 中读取的物理 UID 前 4 字节进行比

对。两者不一致则拒绝访问（返回 `AUTH_FAIL_UID`），此项检查用于防止将凭证数据复制到另一张物理卡片（若要绕过此项检查，攻击者需使用可修改 UID 的“Chinese Magic Card”）。

阶段 5：白名单匹配。通过 `APDU FF B0 00 05 10` 读取 Block 5 的前 8 字节（凭证密钥）。在此之前，白名单文件 `keys.txt` 已被加载到内存（最大支持 64 条记录），每条记录为 16 个十六进制字符表示的 8 字节密钥。通过逐字节比较（`memcmp`）检查卡片上的凭证密钥是否存在于白名单中。不存在则返回 `AUTH_FAIL_NOT_IN_LIST`。白名单文件以 # 开头的行为注释，支持运行时通过重载信号（`SIGHUP`）重新加载，实现不停机的用户权限管理。

阶段 6：有效期检查。通过 `APDU FF B0 00 06 10` 读取 Block 6 中的 4 字节有效期 BCD。与当前系统日期（`localtime()`）比较：若已过期则返回 `AUTH_FAIL_EXPIRED`，有效期为 0 表示永不过期，29991231 为默认的永不过期值。同时校验发行日期的 BCD 编码合法性，格式异常返回 `AUTH_FAIL_FORMAT`。

阶段 7：决策与硬件信号。上述全部检查通过后，`auth_verify_card()` 返回 `AUTH_SUCCESS (0)`。守护进程根据返回值分别调用不同的硬件信号函数：

- 成功：调用 `hw_access_granted()`，发送绿色 LED 闪烁指令（`APDU FF 00 40 08 04 D0 07 00 00`），持续 500ms 后关闭 LED。
- 失败：调用 `hw_access_denied()`，发送红色 LED 闪烁指令三次（每次 200ms 亮、200ms 灭）。

随后，守护进程以保留供电状态（`SCARD_LEAVE_CARD`）断开卡片连接，等待 2000ms 让用户移开卡片，然后回到阶段 1，开始下一周期的检测。

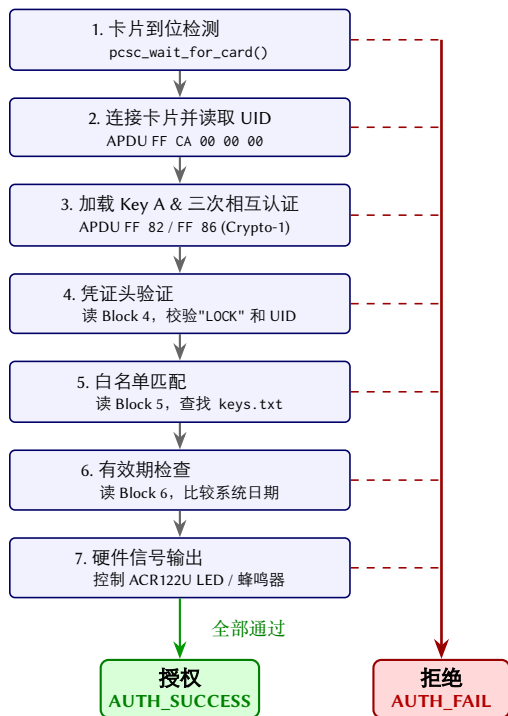


Figure 8: 智能门锁认证与验证七阶段流程。阶段之间以实线箭头连接表示正常流转；任一阶段验证失败均以红色虚线箭头导向「拒绝」框，全部通过后以绿色箭头导向「授权」框。

3.4 Administrative Provisioning

卡片发行与管理由 `lock_admin` 工具完成。其工作流程为：

- 用户通过命令行参数指定访问等级、有效期、自定义 Key A 等配置。
- 程序通过 PC/SC 建立读写器上下文，等待用户放置空白卡片并按回车确认。
- 使用 Key A 对 Sector 1 进行认证，若认证失败则尝试以出厂默认密钥 `FF FF FF FF FF FF` 重试。
- 依次写入 Block 4（凭证头，包含自动获取的卡片 UID）、Block 5（随机生成的 8 字节凭证密钥）、Block 6（当前日期为发行日、参数指定有效期为到期日）。
- 每个块的写入均执行回读验证，确保数据写入正确。写入失败或回读不一致时返回相应错误码。
- 若指定了 `--format-trailer` 标志，程序还将写入 Sector 1 的 Block 7（扇区尾块），设置自定义 Key A 和安全的访问条件。由于写入扇区尾块的操作不可逆（一旦写入错误的访问位可能导致卡片永久锁死），此功能需显式确认。

管理工具成功运行后，将新生成的 8 字节凭证密钥以十六进制格式打印输出，供管理员添加到白名单文件中。

3.5 Security Considerations

从安全分析的视角审视本系统的白方实现，可以识别若干关键安全边界：

Card-UID 绑定。系统在发行时记录卡片的物理 UID 到 Block 4，并在验证时与实时读取的物理 UID 比较。这一措施使得单纯复制 Sector 1 数据到另一张卡片无法通过验证。然而，该防御可被“Chinese Magic Card”（可修改 Block 0 即 UID 的兼容卡片）绕过——攻击者可利用 Proxmark3 同时克隆 UID 和 Sector 1 的全部数据，生成无差别的功能克隆卡。

离线白名单模型。系统的访问控制采用白名单而非吊销列表模型：凭证密钥只有存在于 `keys.txt` 中才能通过验证。吊销用户只需删除其密钥并重启守护进程。这一设计的优势是无卡片侧修改需求，缺点是白名单文件成为系统的关键安全资产——该文件被泄露将导致所有卡片被任意克隆（因攻击者可将任意 8 字节密钥写入卡片并追加到白名单中）。

Crypto-1 的隐蔽性。Key A 以明文形式从宿主机发送到 ACR122U 的 APDU 载荷中。在 USB 层面，这不受 Crypto-1 保护，只是在 USB CCID 通道中以明文传输。若攻击者能够在宿主机 USB 层面进行监听（通过软件 `keylogger` 或 USB 硬件分析仪），即可直接获取 Key A。幸而，在实际部署中，获取 Key A 对于防御层后续介绍的物理层指纹检测仍嫌不足。

物理层不可见性。本系统以 ACR122U 作为读写器，Crypto-1 运算在读写器内部完成，上位机不接触原始 RF 调制波形。这使得上层软件既无法感知射频物理层异常（如克隆卡与正版卡在副载波调制瞬态、载波频率偏移等特征上的细微差异），也无法利用这些差异进行深度防御。这一局限性正是第 5 节引入 HackRF One SDR 辅助物理层指纹检测的根本动机。

4 Crypto-1 Attack

NFC 的交互依赖于无线信号发送。前文提到，NFC 在 13.56 MHz 的高频段工作，使用电感耦合的方式进行数据传输。在卡片与 NFC 接收设备

5 Fingerprinting Defense

6 Discussion and Future Work

7 Conclusion

This project successfully demonstrates the severe security risks associated with static credential exposure over the NFC interface and provides an academic proof-of-concept for dynamic physical-layer defense.

References

- [1] RfidResearchGroup. (2026). *The Proxmark3 Open-Source Firmware Ecosystem*. GitHub Repository.
- [2] ISO/IEC 14443. *Identification cards – Contactless integrated circuit cards – Proximity cards*.
- [3] K. Finkenzeller. *RFID Handbook: Fundamentals and Applications in Contactless Smart Cards, Radio Frequency Identification and Near-Field Communication*. 3rd ed., Wiley, 2010.
- [4] T. Kasper, D. Oswald, and C. Paar. “All You Can Eat or How to Break an NFC MIFARE Classic Card.” In *Black Hat USA*, 2012.
- [5] E. Haselsteiner and K. Breitfuß. “Security in Near Field Communication (NFC): Strengths and Weaknesses.” In *Workshop on RFID Security (RFIDSec)*, 2006.
- [6] F. D. Garcia, G. de Koning Gans, R. Muijters, P. van Rossum, R. Verdonschot, R. Wiegerinck, and J. Horizons. “Dismantling MIFARE Classic.” In *ESORICS*, 2008.